

A graph-based framework for cryptographic risk modeling in the post-quantum transition: TLS 1.3 and TLCP analysis

Andrés F. Herrera¹*, Mehraj Gadimaliyev, Ying Meng, Licheng Wang

School of Cyberspace Science and Technology, Beijing Institute of Technology, Beijing, China

ARTICLE INFO

Keywords:

Post-quantum cryptography
Quantum risk assessment
Graph-based modeling
Cryptographic dependency analysis
TLS
TLCP

ABSTRACT

Context: Quantum computing fundamentally challenges the security assumptions of classical cryptographic systems. Meaningful risk assessment requires a system-level and quantitative approach that models cryptographic dependencies and evaluates their aggregated impact across organizational deployments.

Objective: This study introduces a graph-based framework for quantum risk assessment in cryptographic ecosystems. It models cryptographic dependencies, quantifies structural importance, and supports comparative analysis and visualization to guide post-quantum migration.

Methods: The framework models cryptographic components and interdependencies as directed graphs to derive four core metrics and two composite indicators, capturing risk at primitive, suite, and systemic levels. The methodology is applied to a heterogeneous cryptographic ecosystem representative of an organization using both TLS 1.3 (via OpenSSL) and TLCP (via GmSSL) concurrently, through empirical modeling, metric computation, and visualization.

Results: The graph-based analysis illustrates how the proposed framework identifies structurally fragile constructions and cryptographic components that amplify systemic quantum exposure. Using TLS 1.3 and TLCP as representative case studies, the metrics reveal contrasting structural risk profiles: TLS 1.3 exhibits cryptographic agility but high interdependency, whereas TLCP concentrates exposure in a limited set of mandatory SM primitives. These findings demonstrate how the framework can generate quantitative, ecosystem-wide insights to support prioritization decisions in post-quantum migration planning.

Conclusion: The proposed framework delivers a structured, auditable approach to quantum risk assessment in complex cryptographic ecosystems. By encoding multi-layered dependencies and deriving quantitative metrics, it provides actionable visibility into hidden vulnerabilities and structural interdependencies. The resulting indicators and visualizations support evidence-based prioritization and cross-protocol comparison, establishing a foundational tool for cryptographic inventory and strategic post-quantum migration planning.

1. Introduction

1.1. Motivation

Modern communication security depends on the secure composition of cryptographic primitives within standardized protocols, including TLS, SSH, IPsec, and the IEEE 802.11 Wi-Fi security family [1,2]. These primitives operate not in isolation but within negotiated cipher suites that determine protocol configurations during connection establishment. Consequently, system security depends as much on structural interdependencies and implementation contexts as on individual algorithm strength.

The emergence of quantum computing exacerbates these vulnerabilities. Shor's algorithm is anticipated to compromise public-key primitives reliant on integer factorization and discrete logarithms (e.g., RSA,

DH/ECDH), while Grover's algorithm effectively halves the security level of symmetric primitives [3]. Global roadmaps reflect this urgency, with varying mandates for PQC migration:

- **United States (NIST)** [4]: NIST IR 8547 mandates phased deprecation of vulnerable cryptographic systems starting after 2030 and becoming disallowed after 2035 across Federal systems. [Table 1](#) outlines the detailed transition guidelines.
- **European Union** [5]: The coordinated roadmap mandates national risk analysis by 2026, with full transition for high-risk use cases by 2030 and complete migration across all risk levels by 2035.

* Corresponding author.

E-mail address: af.herrera14@uniandes.edu.co (A.F. Herrera).

- **United Kingdom (NCSC)** [6]: The NCSC roadmap mandates cryptographic discovery and assessment completion by 2028, high-priority migration activities by 2031, and full migration to PQC by 2035.
- **China** [7]: China Pursues cryptographic sovereignty through state driven national standards. Unlike scheduled Western milestones, deployment is tied directly to the finalization of national specifications.

Achieving these deadlines demands a comprehensive quantum-readiness roadmap encompassing cryptographic discovery and inventory, risk assessment, piloting of hybrid and crypto-agile designs, public-key infrastructure modernization, key management practice updates, compliance with evolving standards and regulations, supply-chain assurance, finalizing by a general migration to post-quantum cryptography [8–11].

Significant progress has been made toward quantum-resistant cryptography. NIST's 2016 report [12] launched a multi-year standardization process that has led to the publication of three Federal Information Processing Standards in 2024: FIPS 203, 204, and 205 [13]. These specify ML-KEM for key encapsulation, ML-DSA for digital signatures, and SLH-DSA as a hash-based signature alternative.

In parallel, China has pursued cryptographic sovereignty through a state-driven model. The Chinese Association for Cryptologic Research (CACR) launched a national competition for quantum-resistant asymmetric algorithms in 2020 [7]. Deployment timelines are linked to the finalization of domestic standards, rather than fixed Western milestones.

This approach supports algorithmic independence, as demonstrated by the Transport Layer Cryptographic Protocol (TLCP, GB/T 38636-2020) [14], a national alternative to TLS that mandates the use of the ShangMi (SM) algorithms.

However, a critical gap remains in the literature and practice: the lack of practical, auditable methodologies for conducting comprehensive cryptographic inventories, discovering usage patterns, and assessing risk, particularly for tracing how quantum vulnerabilities propagate through complex, system-level dependencies. Organizations frequently possess only rudimentary asset inventories and lack the granular visibility required to evolve toward prioritized, evidence-based migration roadmaps that accurately capture their true quantum risk posture.

This work tackles this fundamental challenge by introducing a graph-based approach for cryptographic inventory and risk assessment. By modeling cryptographic primitives, protocols, dependencies, and usage contexts as nodes and edges in a structured graph, the method enables precise tracing of quantum vulnerability propagation, identification of latent single points of failure, and quantification of risk across complex system interdependencies. This framework allows organizations to rigorously evaluate their current cryptographic posture and systematically advance toward a post-quantum compliant state.

1.2. Contribution

Regulatory and industry mandates increasingly call for quantum risk assessments to help organizations understand their cryptographic stance and ecosystem in light of emerging quantum threats. Achieving this requires system-level frameworks that capture compositional dependencies, integrate technical and operational factors, and support actionable analysis. Our proposed tool addresses this need by providing a scalable, auditable platform for evaluating quantum risk across real-world cryptographic configurations.

To this end, this article presents a novel, integrated Quantum Risk Assessment framework that directly addresses gaps in current literature and practice. Our contributions are:

1. **Geopolitical and Cross-Protocol Comparison:** Our framework provides a systematic methodology for the comparative analysis of heterogeneous cryptographic ecosystems. By applying the model to both TLS 1.3 and TLCP, we demonstrate how the framework captures the structural and risk-profile differences between modular Western architectures and deterministic national standards.
2. **Operational Risk Visualization:** We propose the Primitive and Cipher Suite Quantum Risk Indicators (P-QRI and CS-QRI), two-dimensional visual models that map technical vulnerability against structural centrality. This approach identifies critical nodes that are both highly vulnerable and deeply embedded, to support the prioritization of risk mitigation efforts.
3. **System-Level Risk Quantification:** We introduce the Systemic Quantum Risk Score (S-QRS), which aggregate primitive-level vulnerabilities into a single scalar value representing the entire ecosystem's exposure. This allows organizations to move from granular asset lists to high-level, auditable evidence of overall quantum readiness.
4. **Cryptographic Ecosystem Visualization:** Our framework uses a graph model to capture primitives, protocols, and hierarchical relationships between subjects and objects, providing organizations with a simplified and organized view of their cryptographic ecosystem.
5. **Standards Alignment:** By adopting a schema conceptually aligned with emerging industry specifications for cryptographic transparency, the framework remains architecturally prepared for integration into automated enterprise ecosystems.

2. Related work

A cybersecurity risk assessment is the structured process of identifying, analyzing, and evaluating potential threats and vulnerabilities to an organization's critical assets, transforming security from a reactive function into a strategic necessity. In the quantum context, a Quantum Risk Assessment (QRA) evaluates an organization's exposure to quantum enabled attacks, providing a quantitative foundation for remediation and migration to quantum secure cryptography. In the following section, we review existing models and frameworks for QRA.

2.1. Quantum risk assessment frameworks

The quantum threat remains inherently time-dependent, a concept first formalized by Mosca [15]. This model utilizes the inequality:

$$X + Y > Z \quad (1)$$

where X is the required confidentiality lifespan of the data, Y is the estimated time to migrate to quantum-resistant cryptography, and Z is the Quantum Adversary Horizon (time until a Cryptographically Relevant Quantum Computer CRQC emerges).

If $X + Y > Z$, the asset is at risk, motivating urgent preparation even amid uncertainty in Z . This temporal imbalance drives the "Harvest Now, Decrypt Later" (HNDL) threat model, where adversaries collect current encrypted traffic for future decryption [9].

Quantum risk severity follows the projected capabilities of a CRQC to execute algorithms such as Shor's and Grover's. To quantify these threats, NIST provides standardized benchmarks through PQC Security Categories (Levels 1–5 shown in Table 2) enabling organizations to model risk based on progressive computational difficulties.

Building on these ideas, the Quantum-Adjusted Risk Score (QARS) [16] extends Mosca's temporal inequality into a multi-factor framework, integrating timeline, data sensitivity, exposure, adversarial capability, and cryptographic longevity to produce quantitative risk scores for prioritizing post-quantum cryptographic migration within the EU's PAREK framework.

Table 1

Cryptographic algorithm classification and transition guidelines (Based on NIST IR 8547 [4]).

Algorithm family	Security strength (bits) ^a	NIST PQC category ^b	Example standardized algorithm (FIPS)	Usage policy ^c
Classical Asymmetric	≤112	N/A	RSA-2048, ECDHE P-224	Deprecated (2030)
	≥128	N/A	RSA-3072, ECDHE P-256	Disallowed (2035)
Post-Quantum Asymmetric	128	1	ML-KEM-512, SLH-DSA-SHA2-128s	✓
	128	2	ML-Dsa-44	✓
	192	3	ML-KEM-768, ML-Dsa-65	✓
	192	4	N/A	✓
	256	5	ML-KEM-1024, ML-Dsa-87	✓
	128	1	AES-128	✓
	128	2	SHAKE128	✓
	192	3	AES-192	✓
Symmetric Cryptography	192	4	SHA3-384	✓
	256	5	AES-256, SHA3-512	✓

^a Security strength for hash functions is based on collision search attack context, which is the limiting factor for digital signatures. This results in $N/2$ bits of security for an N -bit hash output.

^b See Table 2 for a detailed explanation of the NIST PQC Security Categories.

^c The checkmark (✓) indicates the algorithm is currently *Allowed* for use, having been standardized in a FIPS publication (FIPS 203, 204, or 205) [13].

Table 2

NIST PQC security categories (Based on NIST IR 8547 [4]).

Category	Security strength (bits)	Attack type	Example
1	128	Key search on a block cipher with a 128-bit key	AES-128
2	128	Collision search on a 256-bit hash function	SHA-256
3	192	Key search on a block cipher with a 192-bit key	AES-192
4	192	Collision search on a 384-bit hash function	SHA3-384
5	256	Key search on a block cipher with a 256-bit key	AES-256

Extending this approach further, the Cryptographic Agility Risk Assessment Framework (CARAF) [17] builds directly on these concepts by structuring the cryptographic migration process into five distinct phases, guiding organizations in evaluating and enhancing their agility in response to evolving risks. Each phase provides actionable steps for assessing existing cryptographic assets, identifying vulnerabilities, planning replacements, implementing changes, and validating outcomes, ensuring a comprehensive approach to risk management.

Complementing these frameworks, the ATIS Strategic Framework [18] introduces standardized metrics and Key Performance Indicators (KPIs) to systematically measure readiness across operations, products, and governance. This framework leverages scorecards and use cases to support the identification, prioritization, and mitigation of cryptographic vulnerabilities, enabling organizations to benchmark progress and make informed decisions toward secure, resilient deployments.

Finally, models like QUASAR [19] integrate discovery, inventory, and migration planning into a comprehensive strategic architecture designed for long-term cryptographic governance. It employs phased readiness indicators to monitor progress, align security initiatives with organizational objectives, and prioritize mitigation efforts, enabling enterprises to systematically transition toward resilient and future proof cryptographic infrastructures.

Beyond strategic roadmaps, research has increasingly focused on granular, technical evaluations of cryptographic risk. Baseri et al. [20] advance this field by applying the STRIDE threat model to systematically analyze vulnerabilities across algorithmic, certificate, and protocol layers throughout the pre-migration, through-migration, and post-migration stages. Their approach not only identifies potential threats but also provides guidance for mitigation at each stage, enabling organizations to implement targeted interventions and strengthen resilience during the cryptographic transition process.

2.2. Graph-based quantum risk assessment framework

Graph-based approaches have emerged as a powerful paradigm for cybersecurity analytics, offering a scalable means to manage heterogeneous and high-volume data. By modeling entities such as users, hosts, and network events as interconnected nodes and edges, graphs enable the integration of diverse data sources, facilitate relationship driven reasoning, and support advanced analytical methods such as community detection, centrality analysis, and anomaly detection.

Recent surveys highlight their effectiveness for intrusion detection, threat intelligence fusion, and attack path analysis, emphasizing that graph representations improve both situational awareness and automated reasoning across complex cyber ecosystems [21,22].

Hasan et al. [23] present a practical, dependency-aware framework for enterprise migration to post-quantum cryptographic systems. Their approach emphasizes the discovery and inventory of existing cryptographic assets, followed by risk assessment, dependency analysis via graph-theoretic techniques, and remediation roadmaps to prioritize PQC adoption while mitigating continuity risks.

A key strength of the framework is the systematic construction of directed dependency graphs that reveal structural relationships: they map how data assets rely on cryptographic objects (keys, certificates, protocols), which in turn depend on underlying infrastructure components. This visualization enables clearer identification of critical interdependencies and supports more targeted, risk-informed migration planning.

2.3. Comparative overview

Table 3 compares representative quantum risk assessment frameworks with ours. Current methodologies (including temporal models, phased agility frameworks, multi-factor scoring systems, and layered threat modeling) provide valuable support for urgency assessment and high-level migration planning. However, these approaches generally

Table 3

Comparison of selected quantum risk assessment approaches. Quantitative output: Yes = continuous numeric scores or metrics; Partial = semi-quantitative KPIs or scores; No = purely qualitative.

Framework	Analysis scope	Scoring methodology	Quantitative output	Dependency mapping
Mosca [15]	Temporal urgency	Timeline formula	No	No
QARS [16]	Multi factor asset prioritization	Weighted multi-factor formula	Yes	No
CARAF [17]	Organizational agility and phases	5D multiplicative risk	Partial	No
ATIS [18]	Governance and cryptoagility KPIs	Standardized KPIs	Partial	No
Baseri et al. [20]	Multilayer threat modeling	STRIDE impact likelihood	No	No
QUASAR [19]	Enterprise strategic readiness	Readiness indicators	Partial	Yes
Hasan et al. [23]	Dependency mapping	Graph relationship modeling	Partial	Yes
This work	Ecosystem dependency mapping	Graph-derived metrics	Yes	Yes

fall short in capturing or quantifying how quantum vulnerabilities propagate through the dense, interdependent cryptographic ecosystems typical of enterprise scale environments.

We introduce a framework that maps cryptographic ecosystem dependencies via a directed knowledge graph, leveraging RDF triples to capture complex interrelationships. Unlike prior models, this architecture enables automated structural analysis and the computation of graph-derived metrics. This approach allows for the explicit identification of critical nodes and the discovery of traceable risk propagation paths.

These capabilities shift the paradigm from static, qualitative assessments toward dynamic and quantifiable structural evaluations. By providing a mathematical foundation for risk analysis, the framework offers a more robust and actionable strategy for prioritizing post-quantum migration within complex, real world deployments.

3. Technical background: TLS 1.3 & TLCP

Understanding the state space of our study case requires a clear distinction between the modular IETF-standard TLS 1.3 and the prescriptive Chinese national standard TLCP (GB/T 38636-2020). Both protocols rely on combinations of public-key, symmetric-key, and hash-based cryptographic algorithms, all of which are potentially threatened by quantum computing.

3.1. The IETF/NIST standard: TLS 1.3

TLS 1.3 employs a modular and extensible set of IETF-standardized, NIST-approved cryptographic primitives, enabling high algorithmic agility and a comparatively large cryptographic state space [24].

The protocol decouples key exchange (Groups), authentication (Signature Algorithms), and encryption (Cipher Suites), resulting in a high-entropy parameter space. TLS 1.3 also adopts a single-certificate model, in which one entity certificate is used for authentication and parameter signing. A normalized view of the TLS 1.3 parameter space, excluding encryption modes and hash functions, is presented in Table 4.

- 1. Public-Key Cryptography (Authentication):** TLS 1.3 supports several signature schemes for endpoint authentication and handshake parameter signing. These include RSA-based authentication (typically with 2048-bit or larger moduli) and Elliptic Curve Digital Signature Algorithm (ECDSA) over standardized NIST curves like P-256. Additionally, the protocol supports modern Edwards-curve signatures, specifically Ed25519 and Ed448, which offer high security and performance.
- 2. Key Exchange (DHE/EC/DHE):** TLS 1.3 mandates Perfect Forward Secrecy (PFS) by exclusively permitting ephemeral Diffie-Hellman key exchange, either over finite fields (DHE) or elliptic curves (ECDHE). Supported groups include NIST-recommended prime curves as well as Montgomery curves such as X25519 and X448, allowing implementations to select from multiple security-performance trade-offs.

Table 4

Normalized cryptographic parameters specified by TLS 1.3 and supported by the library OpenSSL.

Type	Parameter
(EC)DHE supported groups	secp256r1
	secp384r1
	secp521r1
	x25519
	x448
	ffdhe2048
	ffdhe3072
	ffdhe4096
	ffdhe6144
	ffdhe8192
Signature algorithms	RSA-2048
	ECDSA-P256
	ECDSA-P384
	ECDSA-P521
	Ed25519
	Ed448
Cipher Suites (AEAD)	AES-128
	AES-256
	CHACHA20

- 3. Hash Functions (SHA-2 and SHA-3 Families):** Cryptographic hash functions, primarily from the SHA-2 family (e.g., SHA-256 and SHA-384), are employed for transcript hashing and as the underlying primitives in the HMAC-based Key Derivation Function (HKDF). Additionally, TLS 1.3 supports modern extensible-output functions (XOFs) such as SHAKE256 from the SHA-3 family, providing high-strength collision resistance and flexibility for future-proof deployments.

- 4. Symmetric Encryption (AEAD Ciphers):** Record-layer confidentiality and integrity are provided by AEAD, which combines encryption and authentication. TLS 1.3 mandates AES-GCM, with ChaCha20-Poly1305 as an alternative. Both are classically secure and, with sufficient key sizes, resist feasible quantum attacks.

3.2. The ShangMi (SM) cryptographic algorithm suite in TLCP

The TLCP protocol is built upon China's ShangMi (SM) cryptographic standards, which are mandated for use in regulated domestic systems as a replacement for conventional NIST-defined primitives. Standardized by the Office of State Commercial Cryptography Administration (OSCCA), TLCP adopts a deterministic design that restricts the protocol to a fixed set of 12 cipher suite combinations, reducing protocol state space and facilitating regulatory oversight and cryptographic discovery.

Unlike TLS 1.3, TLCP mandates a dual-certificate model, requiring separate certificates for signature and encryption to enforce cryptographic separation of duties. Additionally, TLCP uniquely supports an Identity-Based Cryptography (IBC) paradigm (e.g., SM9), in which trust is anchored in a centralized Key Management Center, enabling

Table 5

TLCP compliant normalized cryptographic combinations specified by the TLCP protocol.

Key exchange	Signature	Encryption
ECDHE-sm2p256v1	ECC-sm2p256v1	SM4
ECC-sm2p256v1	ECC-sm2p256v1	SM4
IBSDH-SM9	IBS-SM9	SM4
IBC-SM9	IBS-SM9	SM4
RSA-2048	RSA-2048	SM4

certificate-free authentication and key establishment in specific deployment scenarios.

1. **SM2 (Public-Key Cryptography):** A 256-bit elliptic-curve cryptographic scheme supporting digital signatures, public-key encryption, and key agreement [25]. SM2 is defined over the 256-bit prime-field elliptic curve sm2p256v1, providing a 128-bit security level. While structurally comparable to the NIST P-256 curve, it utilizes a distinct set of independently generated domain parameters and a specialized signature algorithm.
2. **SM3 (Hash Function):** A 256-bit iterative cryptographic hash function with structural similarities to SHA-256 but a distinct compression function and message expansion design [26]. SM3 is mandatory within TLCP for digital signature schemes and serves as the underlying hash primitive for key derivation and integrity-related mechanisms, providing collision and preimage resistance under classical and quantum adversary models.
3. **SM4 (Symmetric Block Cipher):** A 128-bit block cipher, functionally comparable to AES-128 [27]. TLCP restricts SM4 to SM4-GCM for authenticated encryption, which provides both confidentiality and integrity, and SM4-CBC for legacy compatibility; CBC encrypts data securely but offers no built-in integrity checks, making it vulnerable to padding oracle and bit-flipping attacks if used without a separate MAC.
4. **SM9 (Identity-Based Cryptography):** An identity based cryptographic framework based on bilinear pairings over pairing-friendly elliptic curves [28]. Although a part of the ShangMi cryptographic stack, SM9 is not negotiated in standard TLCP handshakes. Instead, it is typically used at the application or identity-management layer to enable certificate free services such as identity-based key transport and authenticated key agreement.

4. Methodology

We propose a framework with five stages, as illustrated in Fig. 1.

4.1. Cryptographic discovery

The first stage of the framework assumes the availability of normalized cryptographic configuration data describing an organization's cryptographic assets. This data is treated as an abstract input to the model, independent of the specific discovery mechanism used to obtain it.

In our implementation, the ingestion layer is capable of processing both passive network captures (PCAP) from TLS 1.3 and TLCP to observe negotiated handshake parameters and structured text exports (TXT) from OpenSSL server configurations. This dual input capability enables the framework to bridge observed network behavior with static cryptographic policy definitions, producing a unified and normalized dataset suitable for graph-based dependency modeling.

4.2. Cryptographic inventory database

To manage the complexity of cryptographic metadata, our taxonomy is designed with Software Bill of Materials (SBOM) and Resource Description Framework (RDF) principles, laying the groundwork for alignment with enterprise standards.

Listing 1 Simplified Cryptographic Inventory

```
{
  "Origin": "Local_Research_Node",
  "Protocol": "TLS 1.3",
  "Implementation": "OpenSSL 3.0.17",
  "discovery_metadata": {
    "node_id": "73",
    "Combination": "secp256r1 /
      TLS_AES_128_GCM_SHA256 /
      ecdsa_secp521r1_sha512"
  },
  "supernode_id": "secp256r1 /
    TLS_AES_128_GCM_SHA256 /
    ecdsa_secp521r1_sha512",
  "composition": [
    {
      "id": "TLS_AES_128_GCM_SHA256",
      "name": "TLS13 Cipher Suites",
      "cryptoClass": "Protocol/Cipher-Suite",
      "iana_id": "0x1301",
      "resolved_components": {
        "primitive": { "id": "aes-128", "
          securityLevel": 128, "q_p": 0.5
        },
        "mode": { "id": "gcm" },
        "hash": { "id": "sha-256", "collision
          /SecurityStrength": 128, "q_p":
            0.5 }
      }
    },
    { "id": "secp256r1", "...": "truncated
      for brevity" },
    { "id": "ecdsa_secp521r1_sha512", "...":
      "truncated for brevity" }
  ]
}
```

SBOM formats such as SPDX, CycloneDX, and SWID provide structured representations of software components, relationships, and metadata to support automation and compliance. Of particular relevance for post-quantum cryptography is the Cryptographic Bill of Materials (CBOM) extension, which focuses on cryptographic assets (keys, certificates, algorithms, protocols, and related materials) and their properties.

Our framework mirrors CBOM's hierarchical structure (e.g., as implemented in CycloneDX [29]), enabling organized representation of diverse cryptographic elements. Listing 1 illustrates a simplified example of this taxonomy hierarchy and associated key values relevant to our metrics.

While the current implementation does not yet ingest or generate CBOMs directly, this design ensures future compatibility with CycloneDX and similar standards, facilitating integration with industry cryptographic inventories.

Discovery-phase inventory data is transformed according to the taxonomy and stored in a centralized repository. To model cryptographic dependencies that relational databases cannot easily capture, we adopt an RDF-based graph architecture [30]. Assets and properties are encoded as triples (subject-predicate-object), enabling detailed mapping of relationships across the cryptographic system (Fig. 2).

This RDF design offers extensibility and interoperability: triples can merge telemetry from heterogeneous sources, accommodate new asset

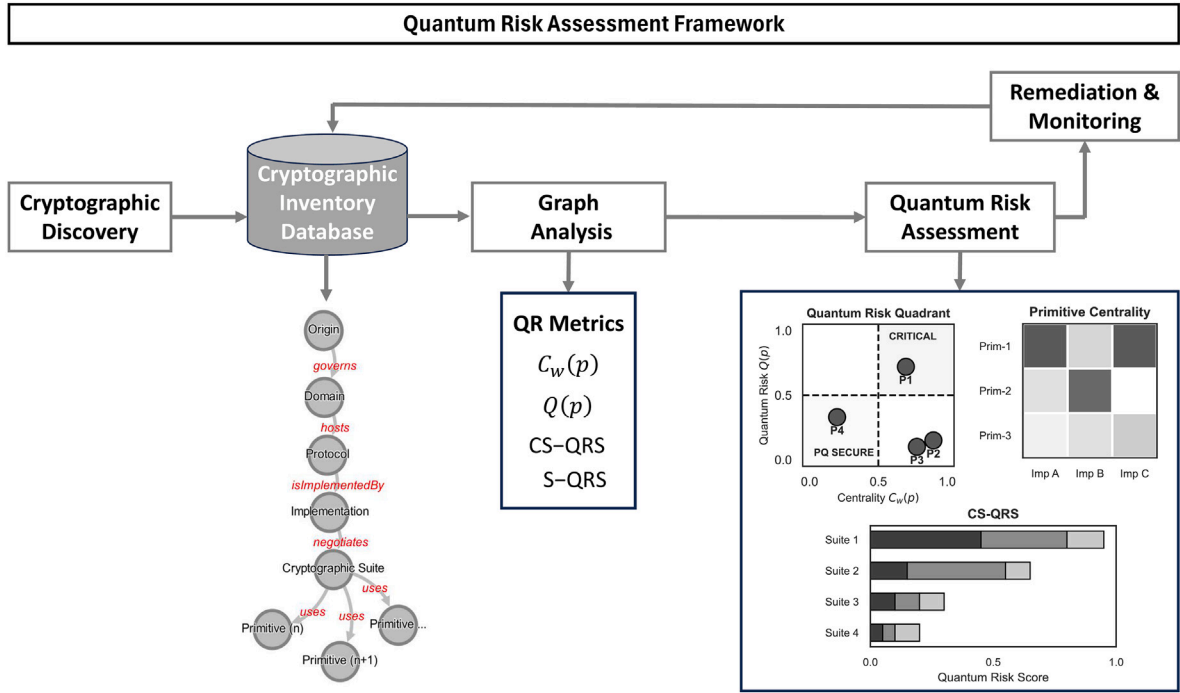


Fig. 1. Quantum Risk Assessment Framework: Cryptographic assets are mapped in a knowledge graph, analyzed with quantum aware risk metrics, and summarized through risk visualizations and systemic scores to reveal ecosystem dependencies, quantum posture, and potential vulnerabilities.

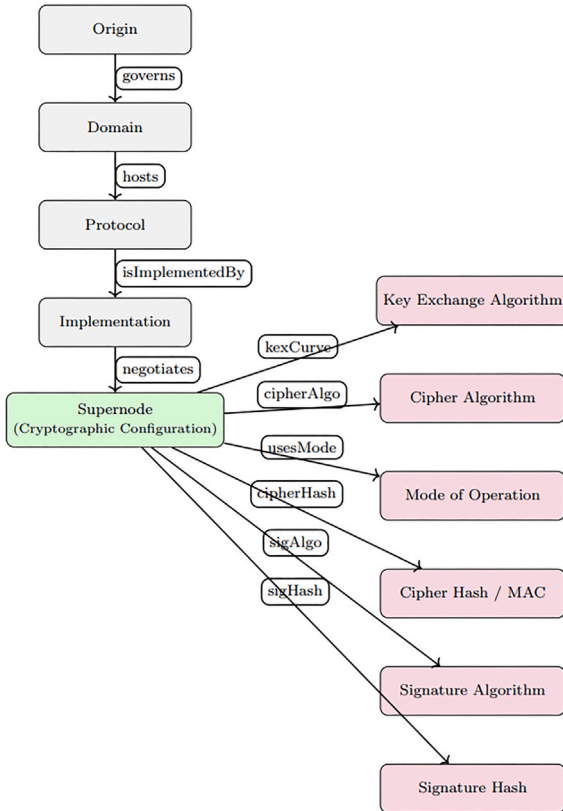


Fig. 2. Ontology representation of the proposed RDF model.

types, and align with evolving standards. Notably, RDF aligns naturally with SPDX's data model [31], positioning the framework for future serialization and enterprise automation pipelines.

4.3. Cryptographic ecosystem graph modeling

We define the cryptographic ecosystem of an organization as the complete, interdependent network of technical and operational elements necessary to deliver and sustain cryptographic protection. This includes protected data assets, protocols, cipher suites, implementations (software libraries, hardware security modules), certificates, keys, runtime configurations, network dependencies, and third-party components.

We formalize this ecosystem as a multi-layered, directed dependency graph

$$G = (V, E),$$

where the vertex set V is partitioned into six functional layers:

$$V = V_{ori} \cup V_{dom} \cup V_{proto} \cup V_{impl} \cup V_{suite} \cup V_{prim} \quad (2)$$

These six layers were derived empirically to partition ontologically distinct elements: from concrete hosts and endpoints (origin), through domain-specific cryptographic applications (e.g., data in transit or data at rest), protocols, implementations, and cipher suites, down to low-level algorithmic primitives. This structure facilitates modular analysis, traceability of risk propagation, and scalable aggregation while remaining extensible.

Directed edges represent compositional or dependency relationships:

$$\begin{aligned} E \subseteq & (V_{ori} \times V_{dom}) \cup (V_{dom} \times V_{proto}) \\ & \cup (V_{proto} \times V_{impl}) \cup (V_{impl} \times V_{suite}) \\ & \cup (V_{suite} \times V_{prim}) \end{aligned} \quad (3)$$

where each edge $(u, v) \in E$ denotes that element v is a component or specialization of u . This layered structure ensures a consistent flow of dependencies from high level cryptographic governance to low level primitives.

Each node $v \in V$ can be enriched with extensible metadata such as standard updates, emerging discoveries, hybrid-readiness, or known vulnerabilities to enable longitudinal and comparative assessments.

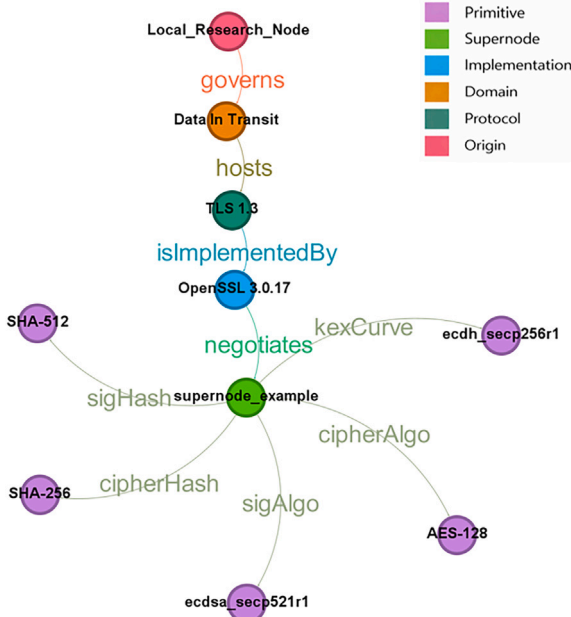


Fig. 3. Color-coded legend showing cryptographic hierarchy categories.

The resulting multi-layer graph provides a systematic view of how vulnerabilities in a single primitive can propagate risk across the entire cryptographic ecosystem. This supports structural analysis through graph-theoretic metrics, the quantification of quantum exposure, and the visualization of dependency chains essential for informed migration planning and continuous monitoring.

By implementing RDF logic with predefined subjects, predicates, and objects, we obtain a multi-layer graph, as shown in Fig. 3.

4.4. Quantum risk assessment

The Primitive Quantum Risk Indicator extends traditional centrality analysis by explicitly incorporating quantum vulnerability, thereby providing a two-dimensional view that captures both structural importance and cryptanalytic exposure. This enriched perspective allows researchers and practitioners to identify and prioritize cryptographic primitives that are most susceptible to emerging quantum threats. By combining information on network centrality with measures of quantum risk, the indicator offers actionable guidance for developing quantum-readiness roadmaps, helping organizations focus resources on the most critical components.

Importantly, this framework is inherently scalable: it can be applied at the primitive level to assess individual cryptographic algorithms, aggregated to the suite level to evaluate combinations of primitives, and extended further to the system level for a comprehensive assessment of overall quantum risk exposure. In this way, the Primitive Quantum Risk Indicator provides a consistent, interpretable, and actionable tool for multi-layered quantum risk assessment and decision support.

4.4.1. Primitive centrality

Let $G = (V, E)$ be a directed graph where V is the set of nodes and E the set of directed edges. Let $p \in V_K$ be a cryptographic primitive node. Each edge $(u, p) \in E$ is assigned a weight $w(u, p) \in \mathbb{R}_{\geq 0}$, which captures the dependency of a cipher suite u on the primitive p .

We distinguish two scenarios:

Static case. All edges are uniformly weighted, i.e., $w(u, p) = 1$ for all $(u, p) \in E$. In this case, the centrality reduces to the in-degree of p , which reflects the number of cipher suites or protocols in which the primitive is structurally embedded.

Table 6

Quantum risk classification by key type and classical security.

Key type	Classical bits	Quantum risk	$Q(p)$
Symmetric	256	PQ SECURE	0
	192	STRONG	0.25
	128	MODERATE	0.5
	112	WEAK	0.75
	< 80	BROKEN	1
Asymmetric	PQC*	PQ SECURE	0
	256	STRONG	0.25
	140–224	MODERATE	0.5
	112–128	WEAK	0.75
	< 80	BROKEN	1

Dynamic case. The edge weight $w(u, p)$ incorporates an additional usage factor (e.g., session frequency, negotiation probability, or traffic volume). This yields a usage-aware measure of centrality that reflects the effective reliance on p in operational settings.

In both cases, the weighted centrality of a primitive p is given by:

$$C_w(p) = \sum_{(u,p) \in E} w(u, p). \quad (4)$$

4.4.2. Primitive quantum risk score

Each primitive $p \in V_K$ is assigned a normalized quantum vulnerability score:

$$Q(p) \in [0, 1], \quad (5)$$

Here, $Q(p) \in [0, 1]$ denotes the quantum risk score of primitive p . A value of $Q(p) = 1$ represents full susceptibility to quantum attacks under the chosen threat model, while $Q(p) = 0$ denotes post-quantum security.

Table 6 presents the quantum risk values adopted within our framework. This mapping correlates classical security levels (expressed in equivalent bits) with both symmetric and asymmetric primitives. These risk levels are synthesized from the NIST PQC security categories previously detailed in Tables 1 and 2.

The underlying rationale assumes an evolving CRQC whose effective qubit capacity increases over time. As this capacity grows, the security of classical cryptographic schemes degrades at different rates. Asymmetric cryptography is affected more rapidly due to polynomial to exponential quantum speedups, such as those enabled by Shor's algorithm, whereas symmetric cryptography degrades more gradually under quadratic speedups, as characterized by Grover's algorithm.

Accordingly, the quantum risk function $Q(p) \in [0, 1]$ models the proportional threat posed by a CRQC to a given cryptographic primitive p , where higher values indicate greater susceptibility under increasing quantum capability.

4.4.3. Cipher suite quantum risk score (CS-QRS)

We define the intrinsic quantum risk of a cipher suite as the average vulnerability of its constituent primitives:

$$\text{CS-QRS}(c) = \frac{1}{|P_c|} \sum_{p \in P_c} Q(p), \quad (6)$$

where c is a cipher suite node, $P_c \subseteq V_K$ is the set of primitives used by c , and $Q(p) \in [0, 1]$ is the quantum vulnerability score of primitive p .

4.4.4. Systemic quantum risk score (S-QRS)

We define the Systemic Quantum Risk Score as the average of all cipher suite scores:

$$\text{S-QRS} = \frac{1}{|C|} \sum_{c \in C} \text{CS-QRS}(c), \quad (7)$$

where C is the set of all cipher suites considered. This metric yields a single scalar value summarizing the average intrinsic vulnerability of the ecosystem.

4.4.5. Primitive quantum risk indicator (P-QRI)

To identify fragile primitives under quantum threat, we combine the structural centrality and quantum vulnerability metrics into a visual indicator. Each primitive p is represented by the pair

$$I_K(p) = (Q(p), C_w(p)). \quad (8)$$

By plotting $Q(p)$ against $C_w(p)$, we obtain a two-dimensional indicator of risk. Primitives in the top-right quadrant (high vulnerability, high centrality) represent urgent migration targets.

4.4.6. Cipher suite risk indicator

To capture both the intrinsic quantum risk of a cipher suite and its operational relevance, we define the two-dimensional indicator

$$I_C(c) = (CS\text{-}QRS(c), C_w(c)), \quad (9)$$

where $CS\text{-}QRS(c)$ is the cipher suite quantum risk score and $C_w(c)$ denotes the weighted centrality of suite c , reflecting either its structural embedding (static case) or its effective usage (dynamic case).

This representation highlights suites that combine high intrinsic vulnerability with high operational exposure. Points in the upper-right quadrant are immediate migration candidates.

4.5. Remediation and monitoring

Recent guidance from NIST, ETSI, and CISA stresses structured post-quantum migration roadmaps with defined timelines, risk-based prioritization, and auditable remediation of cryptographic assets.

The remediation and monitoring layer of our framework operationalizes these recommendations. Using discovery and assessment outputs, it prioritizes assets, data flows, and devices according to quantum risk, data sensitivity, and expected lifetime. This supports protection of high-value assets and long-lived data against “harvest now, decrypt later” attacks, aligning with policy objectives.

Remediation follows standardized strategies: adoption of post-quantum algorithms, deployment of hybrid schemes, and phased deprecation of vulnerable primitives. The framework visualizes hybrid usage across the infrastructure, enabling continuous oversight during transitions and reducing the risk of inconsistent configurations.

Continuous monitoring maintains an up-to-date, visual representation of the cryptographic ecosystem. It detects changes in algorithm usage, key management, or protocol configurations, supporting compliance verification, cryptographic agility, and adaptation to evolving standards. Rather than a one-time effort, this approach tracks progress, measures residual risk, and dynamically adjusts remediation plans as quantum capabilities and requirements mature.

5. Case study: TLS 1.3 and TLCP cryptographic protocols

To demonstrate the framework’s applicability, we simulate a representative organization deploying both OpenSSL [32] (for TLS 1.3) and GmSSL [33] (for TLCP) in a mixed-protocol environment. This setup reflects realistic interoperability challenges in globally distributed infrastructures subject to heterogeneous regulatory constraints.

For TLS 1.3, we deploy an OpenSSL-based server and capture *ClientHello* messages to enumerate supported cipher suites, key exchange groups, and signature algorithms as exposed during negotiation, reflecting the effective cryptographic surface available to conformant clients.

For TLCP, we configure client and server instances, capture protocol exchanges using *tcpdump*, and parse *ClientHello*, *ServerHello*, certificate structures, and key exchange parameters to extract implemented algorithm identifiers and primitives.

The extracted components are combined into all protocol-valid configurations, respecting each protocol’s handshake semantics and constraints. This defines the feasible negotiation space and attack surface for each library.

The resulting datasets are used to construct cryptographic dependency graphs and compute the proposed structural and quantum-risk metrics. By grounding the analysis in observed protocol behavior rather than static library documentation, this approach ensures a controlled, reproducible comparison that preserves real-world deployment characteristics.

5.1. OpenSSL TLS 1.3 configuration space

OpenSSL (v3.0.17) implements a modular TLS 1.3 architecture, allowing independent negotiation of key exchange groups, signature algorithms, and AEAD cipher suites. As shown in Table 4, it supports 10 groups and 3 AEAD suites (AES-GCM-128, AES-GCM-256, ChaCha20-Poly1305). Six signature categories are defined, with RSA expanded into three hash-specific variants (*rsa_pss_rsae_sha256*, *sha384*, *sha512*), yielding eight effective signature primitives and 240 valid handshake configurations. The *rsa_pss_pss* variants are excluded to align with contemporary deployment practices and maintain model tractability.

The configuration space was derived by extracting *ClientHello* parameters from an active OpenSSL server connection and systematically modeling all valid negotiation combinations. This approach simulates the effective cryptographic attack surface exposed during handshake negotiation, capturing the full space of protocol-permitted configurations rather than a single realized session. Specifically, the model graphs all feasible combinations of supported groups, signature algorithms, and cipher suites, including hash functions where applicable.

TLS 1.3 mandates AEAD modes, providing both confidentiality and integrity, which reduces chosen-ciphertext attack risks and simplifies security modeling. With 256-bit keys, AES-GCM retains a 128-bit security margin against Grover’s algorithm. For clarity, encryption modes are modeled as attributes of primitives rather than independent nodes, keeping graphs focused on key exchange and signature mechanisms while preserving mode-level security information.

5.1.1. GmSSL configuration space

GmSSL (v3.1.2 Dev), a Chinese fork of OpenSSL governed by TLCP policies, enforces stricter compliance constraints and integrates SM cryptographic algorithms. TLCP mandates the use of SM2 for key exchange and authentication, SM3 for message integrity, and SM4 for symmetric encryption. While the standard also allows RSA based suites with SM4 and SHA256, our GmSSL deployment does not expose RSA for use; consequently, the normalized dataset is limited to SM2, SM3, and SM4, as summarized in Table 5.

As well, identity-based suites such as SM9 are excluded from the TLCP cryptographic dependency graph due to their distinct architectural requirements. By focusing on the standard PKI-based triplet, the analysis captures the mandatory TLCP handshake process while preserving model clarity.

For clarity, encryption modes are modeled as attributes of primitives rather than independent nodes, keeping graphs focused on key exchange, signature, and encryption mechanisms while preserving mode level security information.

5.2. Implementation and tooling

By applying the five stage methodology described in Section 4 to our normalized datasets, we generated the systemic risk models and indicators analyzed in the subsequent sections. To support scientific transparency and reproducibility, all scripts utilized for TLS/TLCP extraction, cryptographic inventory construction, and graph generation, along with the raw datasets, have been made publicly available via a GitHub repository.¹ The repository includes comprehensive, step by step instructions to replicate the experiments and metric computations reported in this study”.

¹ <https://github.com/herreraaf/Quantum-Risk-Assessment-Framework>

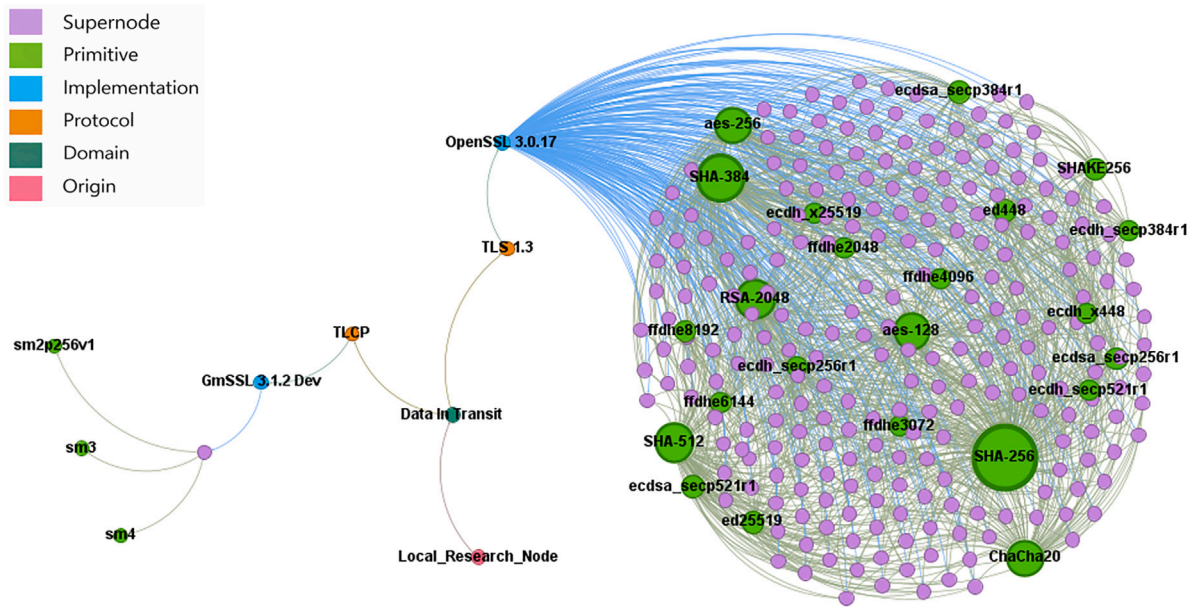


Fig. 4. Network representation of cryptographic suites implemented by each library across protocol versions and cryptographic domains, providing a general overview of the SSL/TLS family that underpins secure communications globally.

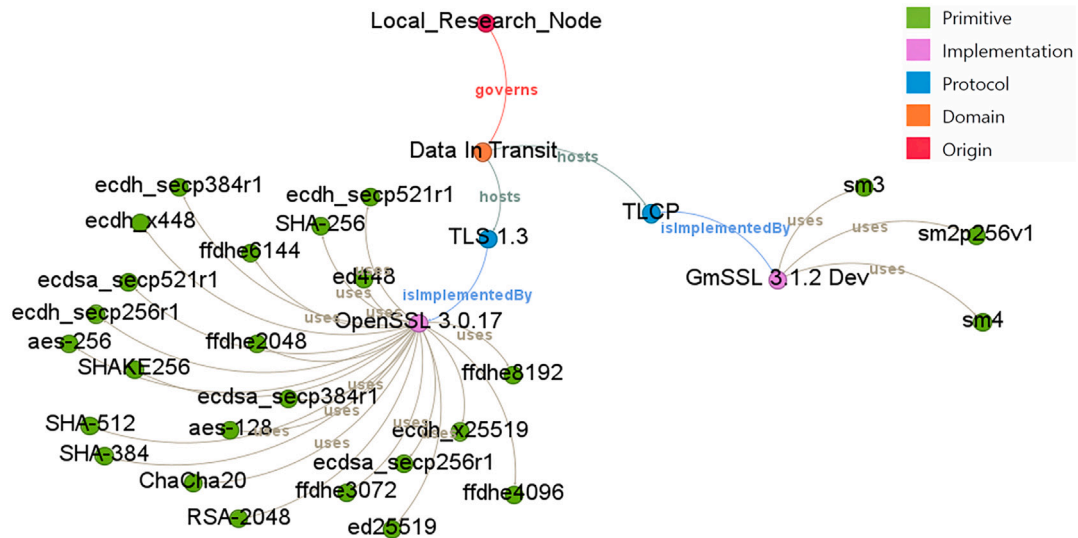


Fig. 5. Primitive level network showing interconnections between GmSSL and OpenSSL components. Despite belonging to different protocols (TLCP and TLS), shared primitives illustrate structural overlaps and dependency patterns across libraries.

6. Results and analysis

This section evaluates the proposed framework in a simulated heterogeneous environment integrating TLS 1.3 (via OpenSSL) and TLCP (via GmSSL). By mapping these divergent protocol implementations into a unified multi-layered dependency graph, the framework automatically generates a visual representation of the organization's cryptographic ecosystem and computes quantum risk metrics. This enables clear explanation of structural interdependencies, node exposure, and potential propagation paths.

6.1. Graph-based visualization

Figs. 4, 5, depict the layered cryptographic networks derived from the simulation. The graph shown in Fig. 5 projects the cryptographic ecosystem from configuration supernodes, representing concrete combinations of key exchange mechanisms, digital signature algorithms,

and cipher suites, onto the primitive layer. This projection exposes shared cryptographic dependencies across multiple configurations and library implementations. Node size reflects the centrality of each primitive, highlighting components that concentrate cryptographic dependency and therefore represent potential sources of systemic risk.

Fig. 4 presents a reduced view containing only cryptographic primitives, providing a high-level overview of the effective negotiation surface. Predicates are included to illustrate how a Resource Description Framework (RDF) representation enables the construction of an extensible knowledge graph, in which nodes carry metadata and semantic relationships. This structure supports the integration of additional contextual information and facilitates a systematic understanding of the apparent complexity of real world cryptographic environments.

Taken together, these visualizations reveal distinct structural topologies. The TLS 1.3 protocol implemented using OpenSSL exhibits a dense and diverse graph, reflecting broad algorithmic support and

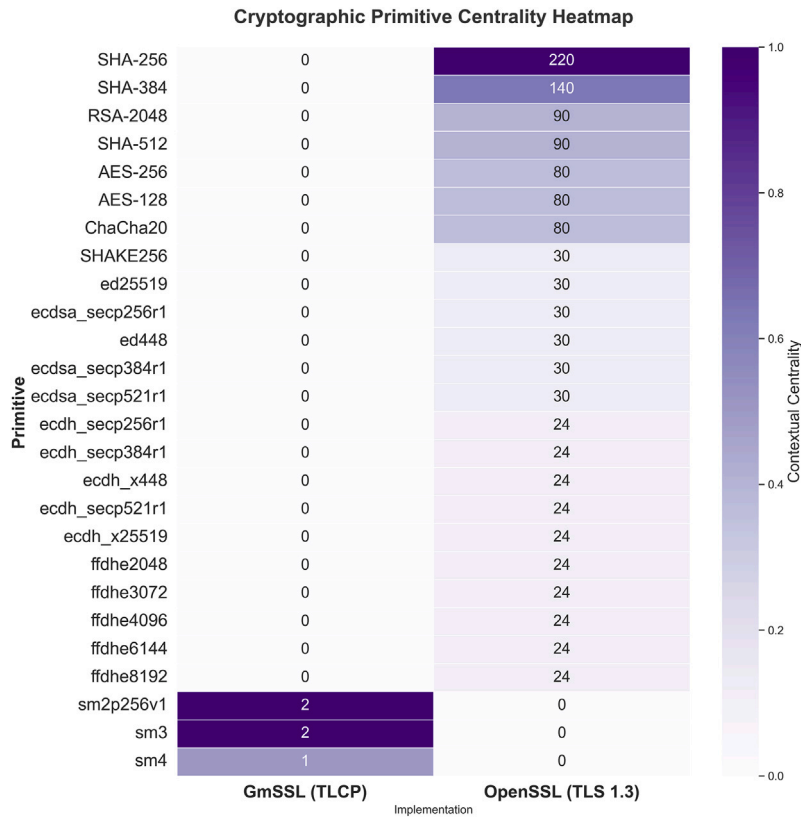


Fig. 6. Primitive centrality heatmap showing usage frequency and structural importance by library and protocol.

high cryptographic agility. In contrast, the TLCP protocol implemented using GmSSL produces a smaller but highly coupled graph, consistent with constrained algorithm choices driven by national cryptographic policies.

6.2. Primitive centrality

Fig. 6 presents the primitive centrality heatmap, visualizing the weighted in-degree $C_w(p)$ of each primitive based on its participation across standardized cipher suites. The vertical axis lists primitives annotated by implementing library, while the horizontal axis separates TLS 1.3 and TLCP results.

Centrality values reflect the full static design space of protocol configurations, not dynamic negotiation behavior, and indicate each primitive's relative influence in the dependency graph. Darker shades denote higher centrality (greater frequency or sharing across configurations), signaling increased systemic exposure.

OpenSSL (TLS 1.3) shows a broad, dense distribution of central primitives, with high values for SHA hashes, RSA, AES-128/256, and ChaCha20. It reflects modular flexibility but strong systemic coupling through widespread reuse. GmSSL (TLCP) displays a concentrated topology, with centrality tightly focused on SM2, SM3, and SM4, a direct result of the mandatory SM suite and limited algorithmic diversity under national standards.

These contrasting patterns illustrate two structural paradigms: OpenSSL's design offers cryptographic agility at the cost of broader interdependency, while GmSSL's constrained approach centralizes risk in a small set of indispensable primitives.

The centrality heatmap serves as a foundational metric for quantifying structural exposure. When combined with quantum vulnerability and systemic indicators, it provides actionable guidance for prioritizing migration targets and post-quantum replacement strategies based on potential systemic impact.

6.3. Primitive quantum risk indicator

Fig. 7 presents the Primitive Quantum Risk Indicator (P-QRI), which combines structural centrality ($C_w(p)$, normalized per implementation) with normalized quantum vulnerability ($Q(p)$) to identify high risk components.

Each point represents a primitive, positioned by centrality on the x -axis and quantum susceptibility on the y -axis. Primitives in the upper-right quadrant combine high structural importance with high quantum risk, marking them as priority targets for post-quantum replacement.

The visualization unifies primitives from OpenSSL (TLS 1.3) and GmSSL (TLCP) in a single joint space, enabling direct cross-protocol comparison. In OpenSSL, asymmetric primitives (DHE, ECDHE, RSA) cluster in the high-risk, low-centrality quadrant due to quantum vulnerability and limited reuse.

Symmetric primitives show greater dispersion: AES-128 lies near the centrality threshold with moderate quantum risk, while AES-256 and ChaCha20 occupy similar centrality positions with substantially lower risk, highlighting their relative robustness. SHA-family hashes exhibit high centrality from widespread use, with SHA-384 standing out as a low-risk, high-centrality primitive due to its longer output mitigating Grover's algorithm impact.

GmSSL presents a contrasting profile: core primitives (SM2, SM3, SM4) dominate the high-risk, high-centrality quadrant, reflecting their mandatory role in TLCP and limited algorithmic diversity under national standards. This results in a compact, tightly coupled structure with risk concentrated in a small set of indispensable components.

Overall, the P-QRI quadrant reveals distinct security postures: OpenSSL offers greater agility with dispersed risk but higher systemic coupling through primitive reuse, whereas GmSSL concentrates structural importance and quantum exposure in a few critical components.

By extending centrality analysis with quantum vulnerability, the P-QRI provides a scalable, two-dimensional view of structural and crypt-analytic exposure, from primitive to suite and system level, delivering actionable guidance for prioritizing quantum readiness roadmaps.

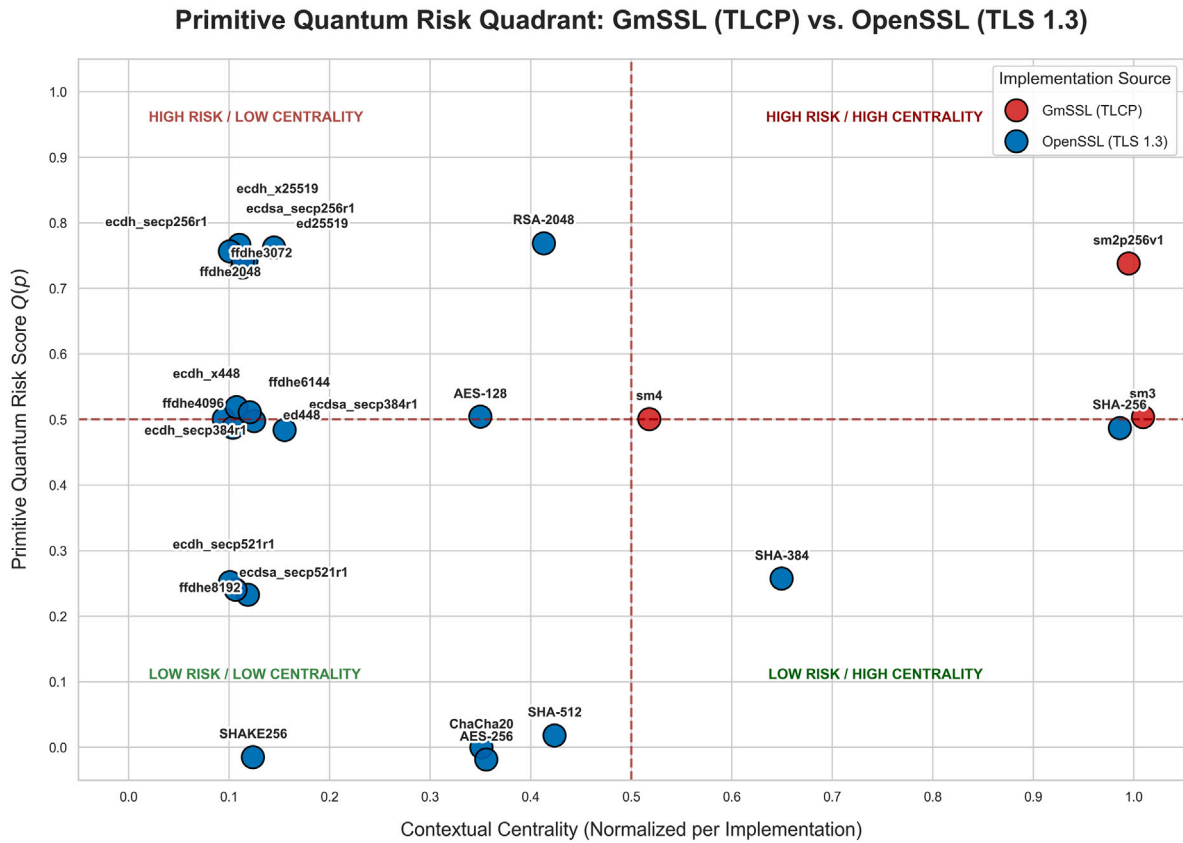


Fig. 7. Cryptographic primitives plotted by structural centrality (x-axis) and normalized quantum vulnerability $Q(p)$ (y-axis). Upper-right points indicate high-risk, high-centrality primitives requiring priority migration.

6.4. Cryptographic suite quantum risk indicator

Fig. 8 presents the Cryptographic Suite Quantum Risk Indicator (CS-QRS), which aggregates quantum vulnerability contributions from all primitives within a given cipher suite. This composite metric captures how individual algorithmic weaknesses accumulate at the suite level, offering a more operational view of quantum exposure.

The figure highlights the three most critical and three most resilient suites. High-risk suites include GmSSL under TLCP (due to reliance on a fixed set of moderately to highly vulnerable SM primitives) and certain OpenSSL TLS 1.3 configurations pairing AES-128 with lower-security key-exchange parameters (e.g., smaller finite-field groups or elliptic curves).

Conversely, the most resilient suites use only higher-strength primitives from OpenSSL, such as stronger symmetric ciphers, larger key sizes, and more quantum-resistant hash functions. These results demonstrate how cryptographic agility and informed primitive selection can substantially reduce suite-level quantum risk.

In a purely structural model, each cipher suite node has uniform centrality (typically one, as suites appear once per implementation). However, when weighted by empirical usage frequencies (e.g., observed negotiation prevalence), centrality reflects real-world adoption.

Thus, the CS-QRS metric can be extended to incorporate these varying centrality weights, enabling the computation of a cipher suite level quantum risk indicator analogous to the P-QRI.

6.5. Systemic quantum risk evaluation

Table 7 presents the Systemic Quantum Risk Score (S-QRS), which aggregates vulnerabilities across primitives and cipher suites to estimate overall quantum exposure. Higher scores reflect greater systemic

susceptibility when combining structural dependencies and quantum cryptanalytic weaknesses.

The framework enables both aggregation (domain-level risk) and disaggregation (tracing risk to specific layers, nodes, or components). In this simulation, the domain “Data in Transit” aggregates an S-QRS of 0.50, representing the combined exposure from all active layers. Disaggregating reveals:

- **TLS 1.3 (protocol level): S-QRS = 0.39.** Moderate exposure driven by algorithmic diversity and potential hybrid compatibility.
- **TLCP (protocol level): S-QRS = 0.60.** Higher exposure driven by structural rigidity and reliance on a fixed set of SM primitives (SM2, SM3, SM4).

While SM algorithms are efficient and standardized, their limited flexibility constrains migration paths. In contrast, TLS 1.3 benefits from broader configuration options and stronger primitives (e.g., AES-256, ChaCha20), offering marginal adaptive resilience during the classical-to-quantum transition.

Overall, S-QRS provides a scalable, single-point metric for systemic quantum risk. When combined with lower-level indicators, it enables organizations to trace exposure to specific domains (e.g., data in transit), hosts, protocols, libraries, or primitives, supporting precise, evidence based prioritization for post-quantum migration.

7. Conclusion and discussion

7.1. Contributions and comparative analysis

This study demonstrates that organizations cannot reliably assess quantum risk using isolated, algorithm level metric. Instead, risk

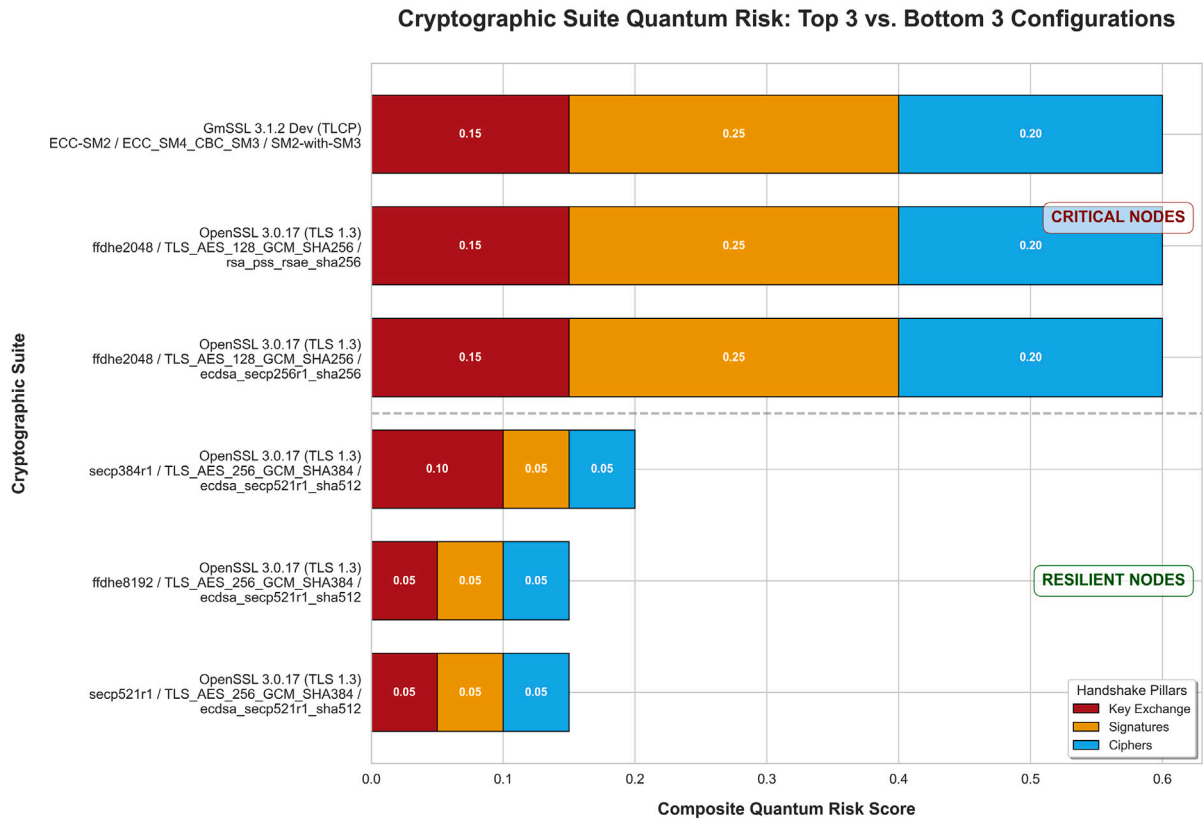


Fig. 8. Cryptographic Suites (y) plotted by its primitives composite quantum risk score (x).

emerges from the complex composition of primitives, protocols, implementations, and deployment contexts. By modeling these relationships at the system level, our framework captures critical dependencies that remain invisible to traditional, primitive-centric analyses.

Modern cryptographic ecosystems encompass a heterogeneous array of assets, including protocols, libraries, certificates, and third-party dependencies. Managing this complexity requires a systematized, ontological approach capable of structuring both the conceptual and technical dimensions of risk. While existing quantum risk assessment methodologies provide valuable guidance, they often exhibit gaps in practical, automated applicability at scale.

As summarized in Table 8, our framework addresses several limitations identified in prior research:

- **Temporal and Governance Models:** Time-based models, such as Mosca's inequality and QARS, focus on temporal urgency but leave discovery and inventory tasks to the organization. Similarly, governance-oriented frameworks like CARAF, ATIS, and QUASAR support strategic planning but rely on qualitative assessments that are difficult to scale in heterogeneous environments.
- **Threat Centric Approaches:** Methods such as those proposed by Baseri et al. offer rigorous multilayer threat modeling but provide primarily qualitative outputs, complicating risk prioritization in large-scale systems.
- **Dependency Based Models:** While existing dependency-based approaches begin to map asset-primitive relationships, they generally lack systemic aggregation and quantitative metrics.

Our framework bridges these gaps by introducing a graph-based representation of the cryptographic ecosystem, mapping heterogeneous elements into explicit, measurable relationships. This approach enables the visualization of dependencies across primitives, protocols, and hierarchical structures, supporting a holistic, system-level assessment. By combining discovery, inventory, and graph modeling, the framework

Table 7

S-QRS breakdown and aggregation from domain to protocol level for a simulated organization using both TLS 1.3 and TLCP.

Layer	KEX	SIG	Cipher	S-QRS
Data in Transit	0.13	0.21	0.16	0.50
TLS 1.3	0.11	0.16	0.12	0.39
TLCP	0.15	0.25	0.20	0.60

provides a technically rigorous and extensible solution suitable for large scale enterprise environments.

Furthermore, the RDF-based ontology ensures adaptability to evolving standards, while our proposed metrics allow organizations to prioritize the mitigation of structurally critical components based on both quantum vulnerability and ecosystem centrality. This quantitative, system level perspective distinguishes our work from prior methodologies and provides immediate practical value for post-quantum migration planning.

7.2. Limitations and future work

The proposed framework provides a structured approach for organizing discovered cryptographic information by leveraging an RDF based representation and a flexible cryptographic taxonomy. This design is intended to support future adaptability to evolving industry standards and to accommodate the needs of large organizations with complex and heterogeneous cryptographic ecosystems. However, in its current form, the framework remains limited in scope.

The current implementation is limited to SSL/TLS handshake analysis and does not yet capture data-at-rest or application-level libraries. As a result, the current analysis represents only a subset of an organization's broader cryptographic ecosystem. While sufficient for validating the framework's core concepts and metrics, this narrow focus does not

Table 8
Comparison of key capabilities across quantum risk assessment frameworks. ✓ = full support, • = limited support, × = no support.

Feature	Time-Based (Mosca, QARS)	Governance (CARAF, ATIS, QUASAR)	Threat- Centric (Baseri et al.)	Dependency- Based (e.g., Hasan et al.)	This work
Multi-layered dependency analysis	×	×	•	✓	✓(RDF ontology)
Dependency quantification	×	×	×	•	✓(Weighted Graph)
Systemic risk metric	×	•	×	×	✓(S-QRS)
Cross- protocol evaluation	×	×	×	×	✓(e.g., TLS 1.3 vs. TLCP)
Decision- support visualization	×	×	•	✓	✓(QR quadrant)

yet capture cryptographic usage in other domains such as data at rest, non-TLS network protocols, hardware security modules, source code repositories, or application-level cryptographic libraries.

Additionally, the framework currently operates as a local research node. This limits its ability to reflect the full cryptographic posture of distributed and large-scale enterprise environments. A more comprehensive assessment would require the deployment of distributed agents capable of securely collecting cryptographic fingerprints across multiple hosts, services, and network segments. Such an extension must carefully address cybersecurity best practices, as the collected data may expose sensitive implementation details and potential vulnerabilities, not only in a post-quantum context but also under classical threat models.

Despite these limitations, the foundational design of the framework enables meaningful future expansion. Planned work includes extending protocol coverage beyond TLS, incorporating cryptographic assets associated with data at rest and alternative communication protocols, and supporting analysis of software, hardware, and configuration-level cryptographic dependencies.

Future efforts will focus on transforming the framework into a usable and extensible tool for diverse organizational contexts. The long term objective is to support accurate quantum-risk assessment by providing organizations with actionable insight into their cryptographic posture, thereby facilitating informed decision making and a smooth transition toward cryptographic mechanisms resilient to large scale quantum computing.

7.3. Concluding remarks

This study presents a graph-based framework for quantum risk assessment. By explicitly modeling primitives, protocols, and their interdependencies, the framework captures system level quantum risk that is not visible through isolated, algorithm level analyses. The proposed metrics and composite indicators provide quantitative, reproducible measures of structural and cryptanalytic exposure, enabling organizations to identify critical primitives and components that may disproportionately contribute to quantum vulnerability.

Empirical evaluation on TLS 1.3 and TLCP shows that the way cryptographic primitives are interconnected can significantly increase overall system vulnerability to quantum attacks. Conversely, protocols that include diverse or redundant primitives can limit risk in specific parts of the system. These findings highlight the need for dependency aware analysis to accurately assess and manage quantum exposure in complex cryptographic ecosystems.

While the framework does not prescribe or implement post-quantum migration strategies, it provides a foundational tool for cryptographic discovery, inventory, and systematic risk assessment. Its ontology-based design, RDF foundation, and alignment with established taxonomies

ensure scalability, adaptability, and interoperability. In summary, this framework offers a rigorous, actionable, and extensible approach for identifying and quantifying quantum vulnerabilities, and supporting informed decision making in preparation for emerging post-quantum threats.

CRediT authorship contribution statement

Andrés F. Herrera: Writing – original draft, Visualization, Validation, Supervision, Software, Project administration, Methodology, Investigation, Formal analysis, Data curation, Conceptualization. **Mehraj Gadimaliyev:** Writing – review & editing. **Ying Meng:** Writing – review & editing. **Licheng Wang:** Writing – review & editing, Writing – original draft, Resources, Project administration, Investigation, Funding acquisition.

Funding

This work is supported by the National Natural Science Foundation of China (NSFC) (No. 62272040). The author gratefully acknowledges the support of the China Scholarship Council through the Chinese Government Scholarship Program (Grant No. 2024GSP005573).

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Data availability

Code link has been indicated in the manuscript.

References

[1] Y. Baseri, V. Chouhan, A. Hafid, Navigating quantum security risks in networked environments: A comprehensive study of quantum-safe network protocols, *Comput. Secur.* 142 (2024) 103883, <http://dx.doi.org/10.1016/j.cose.2024.103883>.
[2] E. Barker, Using Cryptographic Standards in the Federal Government: Cryptographic Mechanisms, NIST Special Publication 800-175B Revision 1, National Institute of Standards and Technology (NIST), 2019, <http://dx.doi.org/10.6028/NIST.SP.800-175Br1>.
[3] A. Amadori, T. Attema, M. Bombar, J.D. Duarte, V. Dunning, S. Etinski, et al., The PQC migration handbook: Guidelines for migrating to post-quantum cryptography TNO, AIVD, and CWI, 2024, https://marc-stevens.nl/research/papers/2024_PQC_Migratie_Handboek_2deEditie.pdf. (Accessed 9 April 2025).
[4] D. Moody, R. Perlner, A. Regenscheid, A. Robinson, D. Cooper, Transition to post-quantum cryptography standards, in: NIST Internal Report 8547, Initial Public Draft, 2024, <http://dx.doi.org/10.6028/NIST.IR.8547.ipd>.

- [5] European Commission and NIS Cooperation Group, A Coordinated Implementation Roadmap for the Transition To Post-Quantum Cryptography, Tech. Rep., European Commission, 2025, <https://digital-strategy.ec.europa.eu/en/library/coordinated-implementation-roadmap-transition-post-quantum-cryptography>. (Accessed 30 December 2025).
- [6] National Cyber Security Centre (NCSC), Timelines for Migration To Post-Quantum Cryptography, Tech. Rep., NCSC, 2025, <https://www.ncsc.gov.uk/guidance/pqc-migration-timelines>. (accessed 30 December 2025).
- [7] Chinese Association for Cryptologic Research (CACR), Announcement of nationwide cryptographic algorithm design competition result, 2020, <https://www.cacrnec.org.cn/site/content/854.html>. (Accessed 30 December 2025).
- [8] National Institute of Standards, Technology (NIST), Migration to Post-Quantum Cryptography, Quantum Readiness: Cryptographic Discovery, NIST Special Publication 1800-38B [14] Standardization Administration of the (Preliminary Draft), 2023, pp. 1800–1838.
- [9] D. Joseph, R. Misoczki, M. Manzano, et al., Transitioning organizations to post-quantum cryptography, *Nature* 605 (2022) 237–243, <http://dx.doi.org/10.1038/s41586-022-04623-2>.
- [10] ETSI, Cyber; Migration Strategies and Recommendations To Quantum Safe Schemes, Technical Report, 103, (619) 2020, https://www.etsi.org/deliver/etsi_tr/103600_103699/103619/01.01.01_60/tr_103619v010101p.pdf. (accessed 31 December 2025).
- [11] Cybersecurity and Infrastructure Security Agency (CISA), National security agency (NSA), in: Quantum Readiness: Post-Quantum Cryptography Preparation, Tech. Rep., National Institute of Standards and Technology (NIST), 2023, <https://www.cisa.gov/resources-tools/resources/quantum-readiness-post-quantum-cryptography-preparation>. (Accessed 31 December 2025).
- [12] L. Chen, S. Jordan, Y.K. Liu, et al., Report on post-quantum cryptography, in: NIST Internal Report, 8105, 2016, <http://dx.doi.org/10.6028/NIST.IR.8105>.
- [13] National Institute of Standards and Technology (NIST), NIST releases first three finalized post-quantum encryption standards, news release, 2024, <https://www.nist.gov/news-events/news/2024/08/nist-releases-first-3-finalized-post-quantum-encryption-standards>. (Accessed 30 December 2025).
- [14] Standardization Administration of the People's Republic of China, Information security technology — Transport layer cryptography protocol (TLCP), 2020, GB/T 38636-2020.
- [15] M. Mosca, Cybersecurity in an era with quantum computers: Will we be ready? *IEEE Secur. Priv.* 16 (2018) 38–41, <http://dx.doi.org/10.1109/MSP.2018.3761723>.
- [16] Š. Grigaliūnas, R. Brūzgienė, Towards a unified quantum risk assessment, *Electronics* 14 (2025) 3338, <http://dx.doi.org/10.3390/electronics14173338>.
- [17] C. Ma, L. Colon, J. Dera, B. Rashidi, V. Garg, CARAF: Crypto agility risk assessment framework, *J. Cybersecur.* 7 (2021) <http://dx.doi.org/10.1093/cybsec/tyab013>, tyab013.
- [18] ATIS, Strategic Framework for Crypto-Agility and Quantum Risk Assessment (ATIS-0100067), Tech. Rep., 2024, <https://atis.org/resources/strategic-framework-for-crypto-agility-and-quantum-risk-assessment/>. (Accessed 31 December 2025).
- [19] A.I. Weinberg, Preparing for the post quantum era: Quantum ready architecture for security and risk management (QUASAR) – a strategic framework for cybersecurity, 2025, arXiv preprint [arXiv:2505.17034](https://arxiv.org/abs/2505.17034).
- [20] Y. Baseri, V. Chouhan, A. Ghorbani, A. Chow, Evaluation framework for quantum security risk assessment: A comprehensive strategy for quantum-safe transition, *Comput. Secur.* 150 (2025) 104272, <http://dx.doi.org/10.1016/j.cose.2024.104272>.
- [21] L. Sikos, Cybersecurity knowledge graphs, *Knowl. Inf. Syst.* 65 (2023) 1–21, <http://dx.doi.org/10.1007/s10115-023-01860-3>.
- [22] K. Liu, F. Wang, Z. Ding, S. Liang, Z. Yu, Y. Zhou, Recent progress of using knowledge framework for cybersecurity, *Electronics* 11 (2022) 2287, <http://dx.doi.org/10.3390/electronics11152287>.
- [23] K.F. Hasan, L. Simpson, M.A.R. Bae, C. Islam, Z. Rahman, W. Armstrong, et al., A framework for migrating to post-quantum cryptography: Security dependency analysis and case studies, *IEEE Access* 12 (2024) 23427–23450, <http://dx.doi.org/10.1109/ACCESS.2024.3360412>.
- [24] E. Rescorla, The Transport Layer Security (TLS) Protocol Version 1.3, IETF., 2018, RFC 8446. <https://datatracker.ietf.org/doc/html/rfc8446>. (Accessed 31 December 2025).
- [25] Office of State Commercial Cryptography Administration (OSCCA), Public key cryptographic algorithm SM2 based on elliptic curves — Part 1: General, 2012, GM/T 0003.1 — 2012.
- [26] Office of State Commercial Cryptography Administration (OSCCA), SM3 cryptographic hash algorithm, 2012, GM/T 0004 — 2012.
- [27] Office of State Commercial Cryptography Administration (OSCCA), SM4 block cipher algorithm, 2012, GM/T 0002 — 2012.
- [28] Office of State Commercial Cryptography Administration (OSCCA), SM9 identity-based cryptographic algorithms, 2016, GM/T 0044 — 2016.
- [29] OWASP CycloneDX, Authoritative Guide To CBOM: Implementing Cryptography Bill of Materials for Post-Quantum Systems and Applications, Tech. Rep., 2024, https://cyclonedx.org/guides/OWASP_CycloneDX-Authoritative-Guide-to-CBOM-en.pdf. (Accessed 31 December 2025).
- [30] W3C, Resource Description Framework (RDF) 1.1 Concepts and Abstract Syntax, W3C Recommendation, 2014, <https://www.w3.org/TR/rdf11-concepts/>. (Accessed 31 December 2025).
- [31] SPDX Workgroup and SPDX Specification Version 3.0.1, The linux foundation, 2024, <https://spdx.github.io/spdx-spec/v3.0.1/>. (Accessed 31 December 2025).
- [32] OpenSSL Project, OpenSSL: Cryptography and SSL/TLS Toolkit, OpenSSL Software Foundation, 2024, <https://www.openssl.org>. (Accessed 31 December 2025).
- [33] G. Wang, GmSSL project, in: GmSSL: Cryptographic Toolkit Supporting Chinese SM Algorithms, 2024, <https://github.com/guanzhi/GmSSL>. (Accessed 31 December 2025).